

Pricing Deception: When a Web-Attack Detector Should Probe Rather Than Decide

Parth Kansal, Amrit Singh Nijjar, and Siddhant Mehta

Department of AIT-CSE, Chandigarh University,
Gharuan, Mohali, Punjab, India
TODO@example.edu

Abstract. TODO (180 words). Compress from 00-abstract.md. Keep, in this order: deception normally happens *after* the decision; we make it a move available while the detector is still undecided; the rule is priced as expected value of sample information; under cost accounting alone the band is empty, so the middle action is derived and not tuned; the randomised-holdout causal estimate; one safety number. Drop the CRS and language-model sentences – they survive in Results.

Keywords: cyber deception · value of information · cost-sensitive detection · web application security · honeytokens.

1 Introduction

TODO

2 Literature Review

TODO

3 Methodology

3.1 System and Threat Model

TODO

3.2 Pricing the Probe as an Information Purchase

At each point in a session the defender holds a belief $p \in [0, 1]$ that the client is hostile, and chooses one of three actions. *Pass* forwards the request to the real application. *Divert* moves the session into the decoy. *Bait* injects an invisible, inert probe into the response and forwards the request unchanged. Each (action, true-class) pair carries a cost fixed in Table 1, which is hashed and frozen before any data is collected, so no threshold derived below can have been tuned to the results.

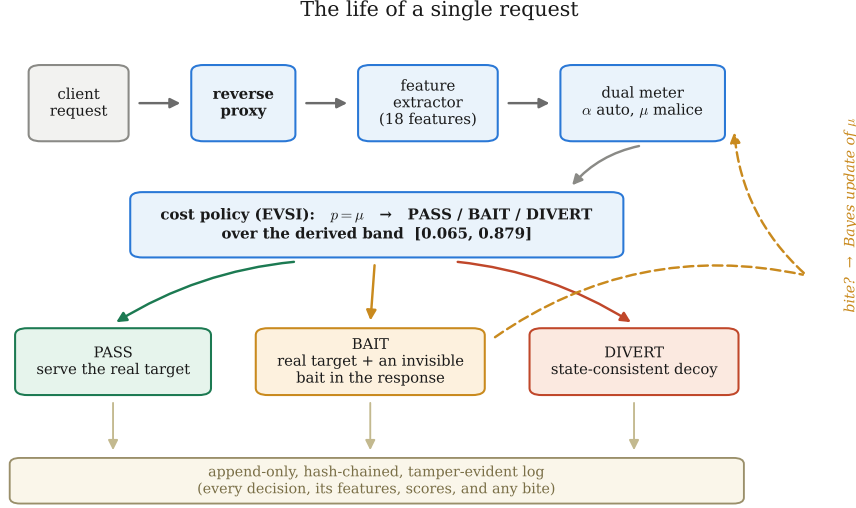


Fig. 1. One request through the proxy: session identity, features, the dual meter, the cost policy, and the three-way decision, all written to a hash-chained log.

Three entries carry the argument. Diverting a benign user is the outcome that must almost never happen, so it is priced two orders of magnitude above any other error. Baiting a hostile client costs exactly what passing one costs: the request still reaches the real application, so the immediate exposure is identical. The only difference between passing and baiting is the small nuisance cost borne by the benign probability mass. Taking expectations under p , each action's immediate expected cost is affine:

$$\mathbb{E}[C_{\text{pass}}] = 25p, \quad \mathbb{E}[C_{\text{bait}}] = 1 + 24p, \quad \mathbb{E}[C_{\text{divert}}] = 200 - 220p. \quad (1)$$

Under cost accounting alone there is no third action. Comparing the first two, $\mathbb{E}[C_{\text{bait}}] - \mathbb{E}[C_{\text{pass}}] = 1 - p \geq 0$ for every belief: baiting is *strictly* more expensive than passing everywhere, by exactly the residual benign-nuisance term. The middle action is therefore never chosen, and the policy collapses to a two-way rule with a single crossover at $25p = 200 - 220p$, i.e. $p^* = 200/245 \approx 0.816$ — one PASS/DIVERT boundary and **no band anywhere in between**. This is the sharpest answer to the natural objection that the middle action is a tuned threshold: *there is no middle action to tune*. It appears only once the information a probe buys is priced.

Pricing the probe. A probe's entire worth is informational: it yields an observation $Z \in \{\text{bite}, \text{no-bite}\}$ that sharpens the belief, and therefore the next decision. We price it by the expected value of sample information (EVSI) [1]:

$$V(p) = \min_a \mathbb{E}[C(a) | p] - \mathbb{E}_Z \left[\min_a \mathbb{E}[C(a) | p'(Z)] \right], \quad (2)$$

where, writing $\beta_a = P(\text{bite} \mid \text{hostile})$ and $\beta_b = P(\text{bite} \mid \text{benign})$ for the two calibrated rates of Section 3.3, $P(\text{bite} \mid p) = p\beta_a + (1-p)\beta_b$ and the posteriors follow by Bayes' rule. Both inner minima are over the same three affine lines, so V evaluates in closed form at any belief; nothing here requires simulation. The rule then prices bait at its immediate cost *net of* the information it buys, and takes the cheapest action: $\text{eff}(\text{bait}) = 1 + 24p - V(p)$.

We claim no new mathematics: EVSI is textbook and the properties below are elementary. The contribution is the application — recognising that a response-side probe *is* a sample-information purchase, which turns the middle option from a heuristic into a derived action.

The band is bounded on both sides by construction. $\min_a \mathbb{E}[C(a) \mid p]$ is a minimum of affine functions and hence concave, so Jensen's inequality gives $V(p) \geq 0$: information never hurts. And $V(0) = V(1) = 0$, because when the belief is already certain no observation can change the decision. The bait band therefore cannot swallow the probability range and cannot be widened by tuning; its edges are pinned by the cost geometry. Both properties are enforced as runtime invariants rather than argued informally.

Bait is chosen exactly where $V(p) > 1 - p$ and the belief is still below the divert line. With the frozen table and the calibrated library, taking the most informative probe applicable to the response in hand, the derived bands are

$$\text{PASS } p < 0.0647, \quad \text{BAIT } 0.0647 \leq p < 0.8793, \quad \text{DIVERT } p \geq 0.8793. \quad (3)$$

The two edges are set by two different probes, which is what taking a maximum over the library means. Note the direction of the upper edge: offering a probe *raises* the divert threshold from 0.816 to 0.879, so a system that can probe is more reluctant to divert an honest user than the same system without one. That falls out of the arithmetic; it was not a design goal.

One term the textbook derivation does not imply. EVSI prices a probe as though its outcome were fresh information, which is true the first time and false the tenth. Valuing every exposure at full price lets a bait-aware attacker who never bites be baited indefinitely rather than diverted — caught by the passive baseline and not by the full system. Decaying the value geometrically in the number of unrewarded showings, $(1 - \beta_a)^k$, restores the guarantee: as the probe stops answering, the rule falls back to the two-action policy.

The conclusions survive both estimated inputs. Sweeping β_a across $[0.05, 0.99]$, and the cost table's one judgement — the ratio of a wrongly diverted user to a missed attacker — across $0.5\times$ to $128\times$ its frozen value, the band is non-empty at every point and the divert threshold never falls below the cost-only boundary. What moves is *where* the boundaries sit, that is, how conservative the system is; never *whether* the third action exists, nor whether a probe could make the system divert earlier than cost accounting alone (it cannot). The frozen table is therefore a choice about conservatism, not one that manufactures the result.

Table 1. The frozen cost matrix. Hashed before any data was collected, so no threshold in the derivation can have been tuned to the results.

	pass	bait	divert
client benign	0	1	200
client hostile	25	25	−20

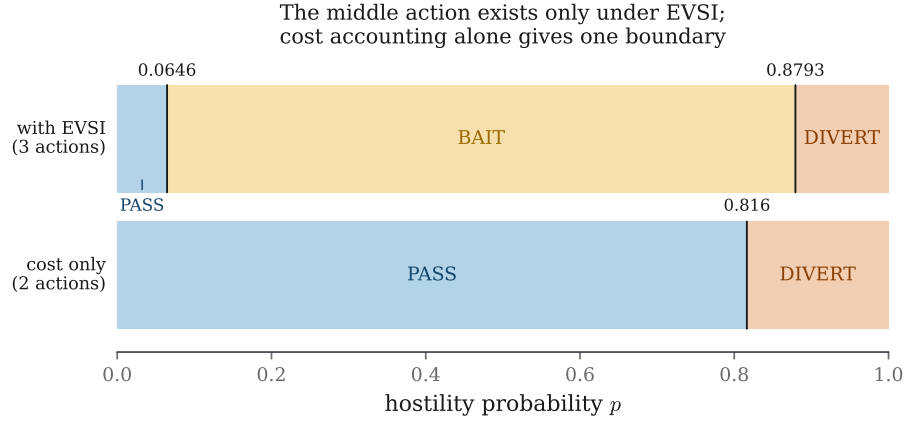


Fig. 2. The derived band. Under cost accounting alone there is a single PASS/DIVERT boundary at $p = 0.816$ and no middle action anywhere; the band appears only once the value of the information a probe buys is priced in.

3.3 Calibrating the Probe

TODO

3.4 Keeping the Decoy Consistent

TODO

4 Results

TODO

5 Discussion

TODO

6 Conclusion

TODO

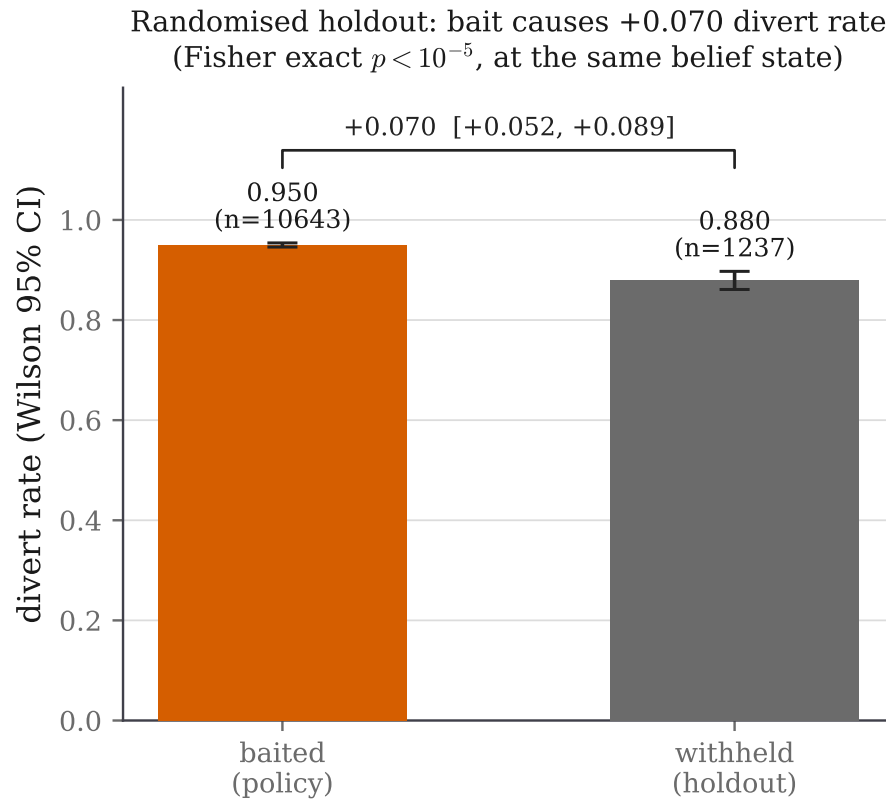


Fig. 3. The randomised holdout. Sessions reaching the probing band are baited or withheld at random, so the gap between the arms estimates the causal effect of the probe rather than comparing two different systems.

References

1. Howard, R.A.: Information value theory. *IEEE Transactions on Systems Science and Cybernetics* **2**(1), 22–26 (Aug 1966). <https://doi.org/10.1109/TSSC.1966.300074>